



Q5

Identify preventive, detective and corrective mitigations

5 Marks

Objective: For the top risks, propose controls in three categories: preventive (stop it), detective (spot it) and corrective (recover from it).

Step-by-Step Algorithm

Step	Phase	Action	Command / Tool	What You Should See
1	SETUP	Take the highest-risk items from the Q4 matrix.	Q4 risk matrix	Top risks selected
2	ANALYSE	For each, list a preventive control that would stop the attack.	Control catalogue	Preventive control
3	ANALYSE	Add a detective control that would raise an early alert.	Control catalogue	Detective control
4	ANALYSE	Add a corrective control that limits or reverses damage.	Control catalogue	Corrective control
5	TEST	Check each control is realistic and maps back to a risk.	—	Controls validated
6	REPORT	Record the three-column control table.	Table template	Mitigation table

Phase key: ● SETUP · ● CONFIGURE · ● EXECUTE · ● TEST · ● ANALYSE · ● REPORT · ● FINISH

Worked Example (with sample values & output)

Mitigation controls (Acme HealthCare)

Risk	Preventive (stop it)	Detective (spot it)	Corrective (recover)
Data theft	Email filtering + MFA	DLP alerts on large exports	Breach notification + credit monitoring
Ransomware	Patch servers + app allowlist	EDR behaviour alerts	Offline backups + restore plan

Each row covers all three control types, so even if prevention fails, the attack can still be detected and recovered from.

Reusable Template

The Colonial Pipeline Ransomware Attack (May 2021):

The **Colonial Pipeline cyberattack** is one of the most significant critical infrastructure breaches in US history. It highlighted the severe real-world physical consequences that can result from a compromise of corporate IT systems.

Three-lines-of-defence template (copy and fill)

Risk	Preventive	Detective	Corrective
Credential Theft & Unauthorized Access	Mandatory corporate-wide MFA on all remote portals + automated password reuse scanning against public leak databases.	Threat intelligence alerts for compromised employee credentials + monitoring for concurrent logins from anomalous geographic locations.	Immediate account lockout + mandatory enterprise-wide password rotation + active session revocation.



Risk	Preventive	Detective	Corrective
Ransomware Encryption & Lateral Movement	Stringent network segmentation separating the corporate IT network from the operational technology (OT) environment.	EDR behavior-based alerts monitoring for unusual encryption processes, shadow copy deletions, or massive file modifications.	Deployment of isolated, immutable offline backups + verified disaster recovery orchestration plan.
Data Exfiltration	Implementing strict Data Loss Prevention (DLP) configurations blocking unauthorized protocol traffic to unknown cloud storage domains.	Continuous network traffic analysis flagging large external data spikes or outbound connections to known DarkSide C2 nodes.	Engagement of specialized third-party digital forensics and incident response (DFIR) teams to isolate endpoints and track stolen data.

Your Output / Screenshot (paste result here):

- **Attack Date:** The attack was discovered on May 7, 2021, leading to a proactive shutdown of the entire pipeline system for several days.
- **Threat Actor:** Carried out by the DarkSide ransomware-as-a-service (RaaS) affiliate group.
- **Initial Access Route:** The attackers gained access to the corporate network via an inactive Virtual Private Network (VPN) profile. The account was compromised because the employee reused a password leaked in a prior public breach, and the VPN account did not have Multi-Factor Authentication (MFA) enabled.
- **Operational Impact:** To protect its operational technology (OT) systems—which directly control the physical movement of oil—Colonial Pipeline proactively shut down its 5,500-mile pipeline, triggering widespread panic-buying, fuel shortages, and spikes in gasoline prices across the US East Coast.
- **Financial & Remediation Action:** The company paid a 4.4 million dollar ransom in Bitcoin within hours of the attack to obtain a decryption tool, though the recovery process was still heavily reliant on corporate backups.